

REPORT 2: Blue Team Operation

Objective: Detect, contain, and investigate the HawkEye intrusion using available SIEM telemetry, EDR logs, and network traffic analysis.

1. Engagement Summary

The Blue Team successfully detected the HawkEye deployment during the exfiltration phase and traced the attack back to the initial phishing vector. The team developed custom SIEM correlation rules, contained the infected host, and performed host-based forensics to map the malware's footprint.

2. Detection & Analysis

Detection 1: Suspicious Process Genealogy (EDR / Sysmon Event ID 1)

Observation: `wscript.exe` spawning `powershell.exe`, which in turn spawned `cmd.exe` to run `systeminfo`.

Rule Logic: Alert when `wscript.exe` or `cscript.exe` spawns `powershell.exe` with command-line arguments containing base64 strings.

Severity: High.

Detection 2: Registry Persistence (Sysmon Event ID 13)

Observation: A registry value was added to `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` pointing to a binary in the user's `AppData` directory.

Rule Logic: Alert on any modification to Run keys where the file path is not a known, signed system binary.

Severity: Medium (Correlated to High when combined with Detection 1).

Detection 3: Anomalous SMTP Traffic (Network Firewall / Zeek)

Observation: The victim endpoint initiated an outbound SMTP connection on port 587 to an unknown IP address, sending a high volume of data (the encrypted zip).

Rule Logic: Alert when an endpoint communicates with an external SMTP server that is not part of the corporate mail gateway list.

Severity: Critical.

3. **Incident Response & Forensics**

1. Containment: The affected host (`WKSTN-04`) was immediately isolated from the network via EDR network containment.
2. Memory Acquisition: Volatility was used to dump RAM. YARA rules identified the HawkEye Reborn payload injected into the `powershell.exe` process.
3. Disk Forensics:
 - * Recovered the malicious VBS from the user's `Downloads` folder.
 - * Identified the dropped payload in
`%AppData%\Roaming\Microsoft\Windows\svhost.exe` (note the typo mimicking `svchost`).
 - * Extracted the SMTP credentials and C2 email address from the binary's strings.

4. **Remediation:**

- * Removed the registry RunKey.
- * Reset all passwords for the compromised user, as well as any credentials stored in the user's browser.
- * Blocked the destination C2 IP and domain at the perimeter firewall.

4. **Blue Team Success Criteria**

- * Alert generated and triaged within 15 minutes of exfiltration.
- * Host isolated before lateral movement could occur.
- * Full attack timeline reconstructed for the Purple Team review.